

Solution Requirement Document

Script-Controlled ACL — Restrict Record Access Based on Field Value

1. Business Requirement

Student/faculty record data in u_institution_details must not be universally visible. Records are restricted by the Branch field so branch-specific staff see only their own branch's data, while admins retain full oversight.

2. Objective

Implement script-controlled ACLs in ServiceNow that dynamically evaluate a user's role together with a record's Branch value, granting/denying Read, Create, Write, and Delete accordingly.

3. Scope

- Applies to u_institution_details (Institution/Student Details).
- Covers Read, Create, Write, Delete across list view, form view, and Service Portal.
- Out of scope: cross-table ACLs, workflow/approval automation, notification triggers.

6. Technical Requirements

Platform: ServiceNow (Global scope). Table: u_institution_details — Student Roll Number (Auto Number), Student Name (Ref-User), Faculty Name (Ref-User), Branch (Choice: ECE/EEE/CSE), Email, Phone Number, Description.

ACL Type: record, Advanced = true, server-side script logic.

Roles: bb1 (Read-EEE), bb2 (Create), bb3 (Write), bb4 (Delete), admin (full override). Data Condition: Branch is EEE on the Read ACL.

7. Assumptions & Constraints

- Only the EEE branch condition is scripted in this phase; ECE/CSE would need similar role+condition pairs later.
- Admin override assumes gs.hasRole('admin') is checked first in every script for fail-safe access.
- Roles are manually assigned; no dynamic/auto role assignment based on user profile fields.

4. Functional Requirements

ID	Requirement
FR-1	System must allow creation of custom roles (bb1, bb2, bb3, bb4) mapped to Read, Create, Write, Delete respectively.
FR-2	System must restrict Read access to records where Branch = EEE only to users holding the bb1 role.
FR-3	System must allow Create access on the table only to users holding the bb2 role.
FR-4	System must allow Write access only to users holding the bb3 role.
FR-5	System must allow Delete access only to users holding the bb4 role.
FR-6	Users with the admin role must bypass all branch-based restrictions and have full access.
FR-7	ACL logic must be enforced via server-side script (gs.hasRole() checks), not client-side, to prevent bypass.
FR-8	Non-EEE branch records (ECE, CSE) must remain completely invisible to bb1-only users — not shown as "access denied," simply absent from the list.

5. Non-Functional Requirements

ID	Requirement
NFR-1	ACL evaluation must not noticeably degrade list-load performance (row-level scripts should stay lightweight).
NFR-2	Access rules must be auditable — every ACL configuration change should be traceable (Updated by/Updated on fields).
NFR-3	Security_admin elevation should be required to create/modify ACLs, preventing unauthorized changes.
NFR-4	Solution must work consistently across list view, form view, and Service Portal.

8. Acceptance Criteria

- ✅ bb1-role user sees only EEE-branch records.
- ✅ User without any bb role sees zero records.
- ✅ bb2 role enables the New button (Create).
- ✅ bb3 role enables inline Edit (Write).
- ✅ bb4 role enables Delete action.
- ✅ Admin sees/edits/creates/deletes all records irrespective of branch.